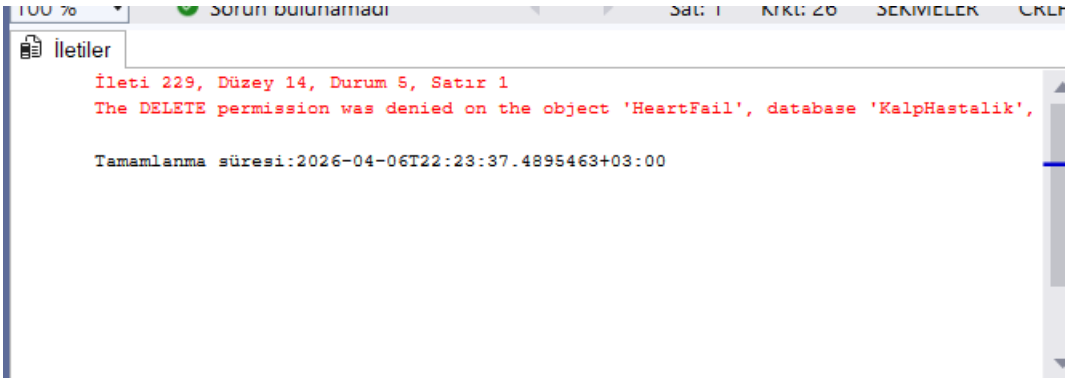
PROJE 3: Veritabanı Güvenliği ve Erişim Kontrolü

1. Giriş

Bu projemizde, veritabanı katmanında siber güvenlik standartlarının sağlanması amaçlanmıştır. En Az Ayrıcalık Prensibi, kullanıcı aktivitelerinin izlenmesi (Audit Logging), 'At Rest' veri şifreleme (TDE) ve SQL Injection saldırılarına karşı savunma mekanizmaları uygulamalı olarak gerçekleştirilmiştir.

2. Erişim Yönetimi (Kullanıcı İzinleri)

Verilere yetkisiz müdahaleyi engellemek için SQL Server Authentication kullanılarak Doktor1 adında kısıtlı bir kullanıcı oluşturulmuştur. Bu kullanıcıya yalnızca veri okuma (db_datareader) yetkisi atanmıştır. Kısıtlı kullanıcı hesabıyla veritabanına giriş yapılıp DELETE işlemi denendiğinde, sistemin bu işleme izin vermediği ve güvenliğin sağlandığı kanıtlanmıştır.



3. Denetim Günlükleri (Audit Logs) ile İz Sürme

Sistemdeki hassas verilere kimin, ne zaman eriştiğini kayıt altına almak için T-SQL scriptleri ile **Server Audit** ve **Database Audit Specification** yapılandırmaları kurulmuştur. Olası arayüz hatalarını aşmak amacıyla loglar doğrudan sistem klasörüne yazdırılmış ve sys.fn_get_audit_file fonksiyonu ile okunmuştur.

SQL

```
EXECUTE AS USER = 'Doktor1';

SELECT TOP 5 * FROM dbo.HeartFail;

REVERT;
```

Yukarıdaki test kodu ile simüle edilen okuma işlemi, güvenlik loglarına anında yansımıştır.

	İşlem Zamanı	Kullanıcı Adı	Veritabanı	Çalıştırılan Sorgu
1	2026-04-06 20:24:21.8241730	Doktor1	KalpHastalik	SELECT * FROM dbo.HeartFail
2	2026-04-06 20:24:23.0650692	Doktor1	KalpHastalik	SELECT * FROM dbo.HeartFail
3	2026-04-06 20:24:23.9065600	Doktor1	KalpHastalik	SELECT * FROM dbo.HeartFail
4	2026-04-06 20:24:24.5706850	Doktor1	KalpHastalik	SELECT * FROM dbo.HeartFail
5	2026-04-06 20:24:24.8523815	Doktor1	KalpHastalik	SELECT * FROM dbo.HeartFail
6	2026-04-06 20:24:25.1087328	Doktor1	KalpHastalik	SELECT * FROM dbo.HeartFail
7	2026-04-06 20:24:25.3572809	Doktor1	KalpHastalik	SELECT * FROM dbo.HeartFail
8	2026-04-06 20:26:32.4720517	Doktor1	KalpHastalik	SELECT TOP (1000) [Age] ...
9	2026-04-06 20:26:35.9644385	Doktor1	KalpHastalik	SELECT TOP (1000) [Age] ...
10	2026-04-06 20:27:13.5229579	Doktor1	KalpHastalik	SELECT * FROM dbo.HeartFail
11	2026-04-06 20:27:31.9830523	Doktor1	KalpHastalik	SELECT TOP (1000) [Age] ...
12	2026-04-06 20:27:52.1100264	Doktor1	KalpHastalik	SELECT * FROM dbo.HeartFail
13	2026-04-06 20:27:52.7457657	Doktor1	KalpHastalik	SELECT * FROM dbo.HeartFail

4. Veri Şifreleme (TDE - Transparent Data Encryption)

Sunucunun fiziksel olarak ele geçirilmesi veya yedek (.bak / .mdf) dosyalarının çalınması ihtimaline karşı veritabanı AES_256 algoritmasıyla şifrelenmiştir. Bu işlem için bir Ana Anahtar ve Sertifika hiyerarşisi oluşturulmuştur. Ayrıca, ileride yaşanabilecek sistem çökmelerine karşı sertifika ve Private Key güvenli bir dizine yedeklenmiştir.

```sql
SELECT
    DB_NAME(database_id) AS [Veritabanı Adı],
    encryption_state AS [Şifreleme Durumu Kodu],
    CASE encryption_state
        WHEN 3 THEN 'Şifreli (Güvende)'
        ELSE 'Şifresiz'
    END AS [Durum]
FROM sys.dm_database_encryption_keys
WHERE database_id = DB_ID('KalpHastalik');
```

00 % Sorun bulunamadı

Sonuçlar | İletiler

	Veritabanı Adı	Şifreleme Durumu Kodu	Durum
1	KalpHastalik	3	Şifreli (Güvende)

5. SQL Injection Zafiyet Simülasyonu ve Engellenmesi

Uygulama katmanından gelebilecek zararlı sorguları simüle etmek için sahte bir giriş ekranı tablosu oluşturulmuştur. Hacker karakterinin ' OR 1=1 -- mantıksal zafiyetini kullanarak sisteme şifresiz giriş yapabildiği gösterilmiştir. Daha sonra bu güvenlik açığı, girdileri kod olarak değil metin olarak algılayan **Parametrik Sorgu** (sp_executesql) mantığı ile tamamen kapatılmış ve saldırı boşa düşürülmüştür.

```
13
14  PRINT '1. HACKER SALDIRISI: Zafiyetli sorgu çalıştırılıyor...';
15
16  EXEC(@GuvensizSorgu);
17  GO
18
19
20  PRINT '--------------------------------------------------';
21  PRINT '2. SİSTEM GÜVENDE: Parametrik sorgu ile koruma devrede...';
22
23  DECLARE @GuvenliGirdi NVARCHAR(100) = ''' OR 1=1 --';
24
25  EXEC sp_executesql
26      N'SELECT * FROM dbo.GirisEkrani WHERE KullaniciAdi = @Kadi AND Sifre = @Sifre',
27      N'@Kadi NVARCHAR(50), @Sifre NVARCHAR(50)',
28      @Kadi = 'Doktor1',
29      @Sifre = @GuvenliGirdi;
```

0 % 1 0

Sonuçlar | İletiler

```
(1 satır etkilendi)
1. HACKER SALDIRISI: Zafiyetli sorgu çalıştırılıyor...
İleti 105, Düzey 15, Durum 1, Satır 7
Unclosed quotation mark after the character string ' OR 1=1 --'.
İleti 102, Düzey 15, Durum 1, Satır 7
Incorrect syntax near ' OR 1=1 --'.
--------------------------------------------------
2. SİSTEM GÜVENDE: Parametrik sorgu ile koruma devrede...

(0 satır etkilendi)

Tamamlanma süresi:2026-04-08T17:55:33.7146547+03:00
```

6. Sonuç

Bu proje kapsamında; yetkilendirme, izleme, kriptografik veri koruma ve uygulama güvenliği (injection önleme) adımları MSSQL üzerinde başarıyla entegre edilmiş olup, sistem dış ve iç tehditlere karşı korunaklı hale getirilmiştir.